

HTB Starting Point — Tier 0

DANCING

Guía de Teoría: Protocolo SMB

Preparación pre-máquina · RedTeamLab 2026
Cert path: CPTS → OSCP+

1. ¿Qué es SMB?

SMB (Server Message Block) es un protocolo de red para compartir archivos, impresoras y recursos entre equipos de una red. Opera en la capa de aplicación y usa **TCP como transporte**. Es el protocolo central de las redes Windows.

Originalmente desarrollado por IBM (1983), adoptado y extendido por Microsoft. Hoy es omnipresente en entornos corporativos: cada carpeta compartida en Windows usa SMB. En Linux lo implementa **Samba**.

Puertos estándar

Puerto	Protocolo	Uso
139/TCP	NetBIOS sobre TCP	SMB legacy — Windows antiguo
445/TCP	SMB directo sobre TCP/IP	SMB moderno — el que verás en HTB y prod
137-138/UDP	NetBIOS	Resolución de nombres NBT (legacy)

■ En pentesting, puerto 445 abierto = SMB. Es uno de los servicios más explotados en entornos Windows y Active Directory. Siempre enumerar si está presente.

2. Versiones de SMB — Historia y Vulnerabilidades

La versión de SMB determina qué ataques son posibles. Identificarla en el escaneo es crítico para decidir el vector.

Versión	OS	Estado	Vulnerabilidades conocidas
SMBv1	Windows XP/2003	■ Obsoleto	EternalBlue (MS17-010), WannaCry, NotPetya
SMBv2	Vista/2008	■■ Legacy	SMBGhost (CVE-2020-0796) en v2.1
SMBv2.1	Win7/2008R2	■■ Legacy	SMBGhost si no parchado
SMBv3	Win8/2012+	■ Actual	SMBGhost en v3.1.1 sin parche
SMBv3.1.1	Win10/2016+	■ Actual	Cifrado AES — más seguro
Samba	Linux/Unix	Depende versión	Muchos CVEs históricos (3.x, 4.x)

■■ EternalBlue (MS17-010) explota SMBv1. Si el escaneo muestra SMBv1 habilitado, es un hallazgo crítico inmediato. Dancing NO usa EternalBlue — usa misconfiguration de acceso anónimo.

3. Cómo Funciona SMB

Conceptos clave

- **Share (recurso compartido):** carpeta o dispositivo expuesto en la red vía SMB. Ejemplos: `\\servidor\C$, \\servidor\IPC$, \\servidor\ADMIN$`
- **IPC\$ (Inter-Process Communication):** share especial que permite enumeración remota sin necesidad de acceder a archivos. Frecuentemente accesible anónimamente — gold mine para reconocimiento.
- **C\$, ADMIN\$, SYSVOL, NETLOGON:** shares administrativos por defecto en Windows.

Shares administrativos por defecto

Share	Contenido	Relevancia pentest
C\$	Raíz del disco C:	Acceso total al sistema si tienes permisos
ADMIN\$	C:\Windows	Usado por herramientas como PsExec
IPC\$	Named pipes	Enumeración de usuarios, grupos, políticas
SYSVOL	Políticas de grupo (GPO)	GPP passwords — credenciales en texto plano
NETLOGON	Scripts de inicio de sesión	Scripts con credenciales hardcodedas

Flujo de conexión SMB

1. Cliente inicia conexión TCP al puerto 445 del servidor.
2. Negociación de protocolo: el cliente propone versiones, el servidor elige la mayor compatible.
3. Autenticación: anónima (null session), usuario/contraseña, o Kerberos en dominios AD.
4. Acceso a shares: cliente lista shares disponibles y accede a los que tiene permisos.

4. Autenticación en SMB

Null Session (Sesión Nula) — vector de Dancing

Una null session es una conexión SMB **sin credenciales**: usuario vacío, contraseña vacía. Permite conectarse al share **IPC\$** y en algunos casos a otros shares mal configurados.

```
smbclient -L //10.10.10.XXX -N
# -L lista shares disponibles
# -N no pide contraseña (null session)
```

■ Si el servidor responde con una lista de shares a una null session, hay misconfiguration. Explora cada share: algunos tendrán acceso anónimo de lectura (o incluso escritura).

Autenticación con credenciales

```
smbclient //10.10.10.XXX/share -U usuario
# Pedirá contraseña

# Con contraseña inline
smbclient //10.10.10.XXX/share -U usuario%contraseña
```

Tabla de escenarios de autenticación

Escenario	Comando	Qué esperar
Null session	smbclient -L //IP -N	Lista de shares o error
Guest login	smbclient //IP/share -U guest%"	Acceso sin contraseña real
Con creds válidas	smbclient //IP/share -U user%pass	Acceso autenticado
Pass-the-Hash (AD)	smbclient //IP/share -U user%hash --pw-ntlm	Hash 2 en adelante

5. Herramientas de Enumeración SMB

smbclient — cliente interactivo

```
# Listar shares (null session)
smbclient -L //10.10.10.XXX -N

# Conectar a un share
smbclient //10.10.10.XXX/nombre_share -N

# Dentro de smbclient:
ls                # listar archivos
cd carpeta        # cambiar directorio
get archivo.txt   # descargar archivo
mget *            # descargar todo
put archivo.txt   # subir archivo
pwd              # directorio actual
exit             # salir
```

smbmap — permisos por share

```
# Null session
smbmap -H 10.10.10.XXX

# Con credenciales
smbmap -H 10.10.10.XXX -u usuario -p contraseña

# Listar contenido de un share
smbmap -H 10.10.10.XXX -r nombre_share
```

crackmapexec (CME) — multipropósito

```
# Info del host y dominio
crackmapexec smb 10.10.10.XXX

# Con credenciales
crackmapexec smb 10.10.10.XXX -u user -p pass

# Enumerar shares
crackmapexec smb 10.10.10.XXX -u "" -p "" --shares

# Enumerar usuarios
crackmapexec smb 10.10.10.XXX -u "" -p "" --users
```

enum4linux — enumeración completa

```
# Enumeración completa (verbose)
enum4linux -a 10.10.10.XXX

# Solo usuarios
enum4linux -U 10.10.10.XXX

# Solo shares
enum4linux -S 10.10.10.XXX
```

nmap — scripts NSE para SMB

Script NSE	Qué detecta
smb-security-mode	Nivel de seguridad, null sessions habilitadas
smb2-security-mode	Configuración de seguridad SMBv2
smb-enum-shares	Lista shares y permisos
smb-enum-users	Enumera usuarios del sistema
smb-vuln-ms17-010	EternalBlue (SMBv1)
smb-vuln-ms08-067	MS08-067 NetAPI (XP/2003)

Ejecutar todos los scripts SMB

```
nmap -p 445 --script "smb-*" 10.10.10.XXX
```

Scripts específicos

```
nmap -p 445 --script smb-security-mode,smb-enum-shares 10.10.10.XXX
```

6. Flujo de Ataque SMB — Árbol de Decisión

Cuando nmap detecta **puerto 445 abierto**, seguir este orden:

- [] 1. nmap -p 445 --script smb-security-mode,smb-enum-shares <IP>
- [] 2. smbclient -L //<IP> -N # null session → lista shares?
- [] 3. smbmap -H <IP> # qué permisos tiene cada share?
- [] 4. Conectar a cada share accesible: smbclient //<IP>/<share> -N
- [] 5. ls -la + explorar subdirectorios + buscar credenciales/configs
- [] 6. mget * para descargar todo lo que tengas permiso de leer
- [] 7. Si nada anónimo: buscar versión SMB → CVEs aplicables
- [] 8. Si tienes credenciales: repetir con -U user%pass

Comandos de referencia rápida dentro de smbclient

Comando	Acción
ls	Listar archivos y carpetas
ls -la	Listar con permisos y ocultos
cd carpeta	Entrar en directorio
get archivo	Descargar un archivo
mget *	Descargar todo el directorio actual
put archivo	Subir archivo (si tienes permiso de escritura)
pwd	Ver directorio actual en el share
!ls	Listar tu directorio LOCAL (con ! ejecutas comandos locales)
!pwd	Ver tu directorio local actual
exit	Salir de smbclient

7. SMB y Seguridad — Vectores Principales

1. Null Session / Acceso Anónimo

Cuando un servidor permite conexiones sin autenticación, expone la superficie de ataque completa. En entornos legacy esto era común para compartir recursos públicos. Hoy es una misconfiguration crítica.

Impacto: enumeración de usuarios, grupos, políticas de contraseñas, shares internos. En casos extremos, acceso a archivos sensibles sin credenciales.

2. EternalBlue — MS17-010 (SMBv1)

Vulnerabilidad en el parser de SMBv1 que permite RCE sin autenticación. Explotada masivamente por WannaCry (2017) y NotPetya. Módulo en Metasploit: `exploit/windows/smb/ms17_010_eternalblue`. Afecta Windows 7/2008 sin parche.

Dancing NO usa EternalBlue. Pero identificar SMBv1 en un escaneo siempre debe reportarse.

3. NTLM Relay

Un atacante intercepta autenticaciones NTLM y las redirige a otro servicio para autenticarse sin conocer la contraseña. Herramienta: Responder + `ntlmrelayx`. Relevante en Fase 2 del roadmap.

4. GPP Passwords (Group Policy Preferences)

Antes de 2014, Windows almacenaba contraseñas en archivos XML dentro de SYSVOL share, cifradas con una clave AES *publicada por Microsoft*. Cualquiera con acceso al share puede descifrarlas: `gpp-decrypt`. Máquina relevante: Active (Fase 2).

Tabla de vulnerabilidades SMB — referencia rápida

Vuln	CVE	Versión afectada	Impacto	Máquina HTB
EternalBlue	MS17-010	SMBv1 — Win7/2008	RCE sin auth	Blue (Fase 0)
SMBGhost	CVE-2020-0796	SMBv3.1.1 (Win10 1903)	RCE preauth	—
MS08-067	CVE-2008-4250	Win XP/2003	RCE sin auth	Legacy (Fase 0)
GPP Pass	—	Cualquier AD pre-2014	Creds en texto	Active (Fase 2)
Null Session	—	Cualquier SMB mal conf.	Enumeración	Dancing (SP Tier 0)

8. MITRE ATT&CK; Mapping — SMB

Táctica	Técnica	ID	Aplicación en SMB
Reconnaissance	Network Service Discovery	T1046	nmap detecta 445 abierto
Initial Access	Valid Accounts: Default Accounts	T1078.001	Null session / guest login
Discovery	Network Share Discovery	T1135	smbclient -L, smbmap
Collection	Data from Network Shares	T1139	get/mget en shares accesibles
Lateral Movement	SMB/Windows Admin Shares	T1021.002	Psexec, CME exec vía SMB
Credential Access	Credentials in Files	T1552.001	GPP passwords, configs en shares
Exfiltration	Exfiltration Over SMB	T1048.002	Transferencia datos vía SMB

9. Perspectiva Defensiva

¿Qué detectaría un Blue Team / Threat Hunter?

Fuente	Evento detectable
Windows Event Log	4624 (login) con null session desde IP externa; 5140 (share access)
Sysmon	EventID 3 — conexión de red a 445; EventID 18 — named pipe
IDS/Firewall	Tráfico 445 desde IPs no corporativas o no autorizadas
NetFlow	Volumen inusual de tráfico SMB (mget masivo = muchos GET en tiempo corto)
SIEM	Correlación: null session + enum de shares + descarga de archivos = reconocimiento SMB

IOC (Indicators of Compromise) en Dancing

- Conexión TCP/445 desde IP externa no autorizada
- Login SMB con usuario vacío / null session
- Descarga de flag.txt — nombre sospechoso, pero IOC de exfiltración
- Múltiples comandos LIST/GET en corto tiempo = enumeración automatizada

Remediación

- **Deshabilitar SMBv1:** Set-SmbServerConfiguration -EnableSMB1Protocol \$false
- **Deshabilitar null sessions:** GPO → Restrict anonymous access to named pipes and shares
- **Auditar shares:** revisar permisos de cada share — principio de mínimo privilegio
- **Firewall perimetral:** bloquear 445/TCP entrante desde internet — SMB nunca debe estar expuesto
- **Segmentar red:** SMB solo entre segmentos internos necesarios

10. Checklist Pre-Ataque — Puerto 445 Abierto

```
[ ] 1. nmap -p 445 --script smb-security-mode,smb-enum-shares <IP>
[ ] 2. Null session: smbclient -L //<IP> -N
[ ] 3. Permisos: smbmap -H <IP>
```

- [] 4. Conectar a shares READ/WRITE: `smbclient //<IP>/<share> -N`
- [] 5. Dentro del share: `ls -la` → explorar → `mget *`
- [] 6. Buscar: contraseñas, configs, claves SSH, scripts
- [] 7. Identificar versión SMBv1? → anotar CVE MS17-010
- [] 8. Documentar: shares encontrados, permisos, archivos descargados

11. Preguntas de Estudio — Autoevaluación

Responde antes de atacar Dancing. Si no puedes, repasa la sección correspondiente.

1. ¿En qué puerto opera SMB moderno y cuál es el legacy? ¿Por qué importa esta diferencia?
 2. ¿Qué es una null session en SMB? ¿Por qué existe y por qué es un riesgo?
 3. ¿Qué es el share IPC\$ y por qué es relevante en pentesting aunque no contenga archivos?
 4. ¿Qué comando usas para listar shares en SMB sin credenciales?
 5. ¿Qué hace **smbmap** que no hace **smbclient** directamente?
 6. Dentro de **smbclient**, ¿cómo ejecutas un comando en tu máquina local sin salir de la sesión?
 7. ¿Qué es EternalBlue (MS17-010) y qué versión de SMB afecta? ¿Afecta a Dancing?
 8. ¿Qué son las GPP Passwords y por qué son relevantes para AD? ¿En qué share se encuentran?
 9. ¿Qué EventID de Windows registra un acceso a un share de red? ¿Y un login exitoso?
 10. ¿Cómo deshabilitas SMBv1 en PowerShell? ¿Por qué es importante hacerlo?
-

12. Referencias

- **HackTricks — Pentesting SMB:** <https://book.hacktricks.xyz/network-services-pentesting/pentesting-smb>
 - **MITRE T1021.002 — SMB/Windows Admin Shares:** <https://attack.mitre.org/techniques/T1021/002/>
 - **MS17-010 (EternalBlue):** <https://www.exploit-db.com/exploits/42315>
 - **smbclient man page:** <https://www.samba.org/samba/docs/current/man-html/smbclient.1.html>
 - **CrackMapExec docs:** <https://wiki.porchetta.industries/>
 - **HTB Starting Point — Dancing:** <https://app.hackthebox.com/starting-point>
-